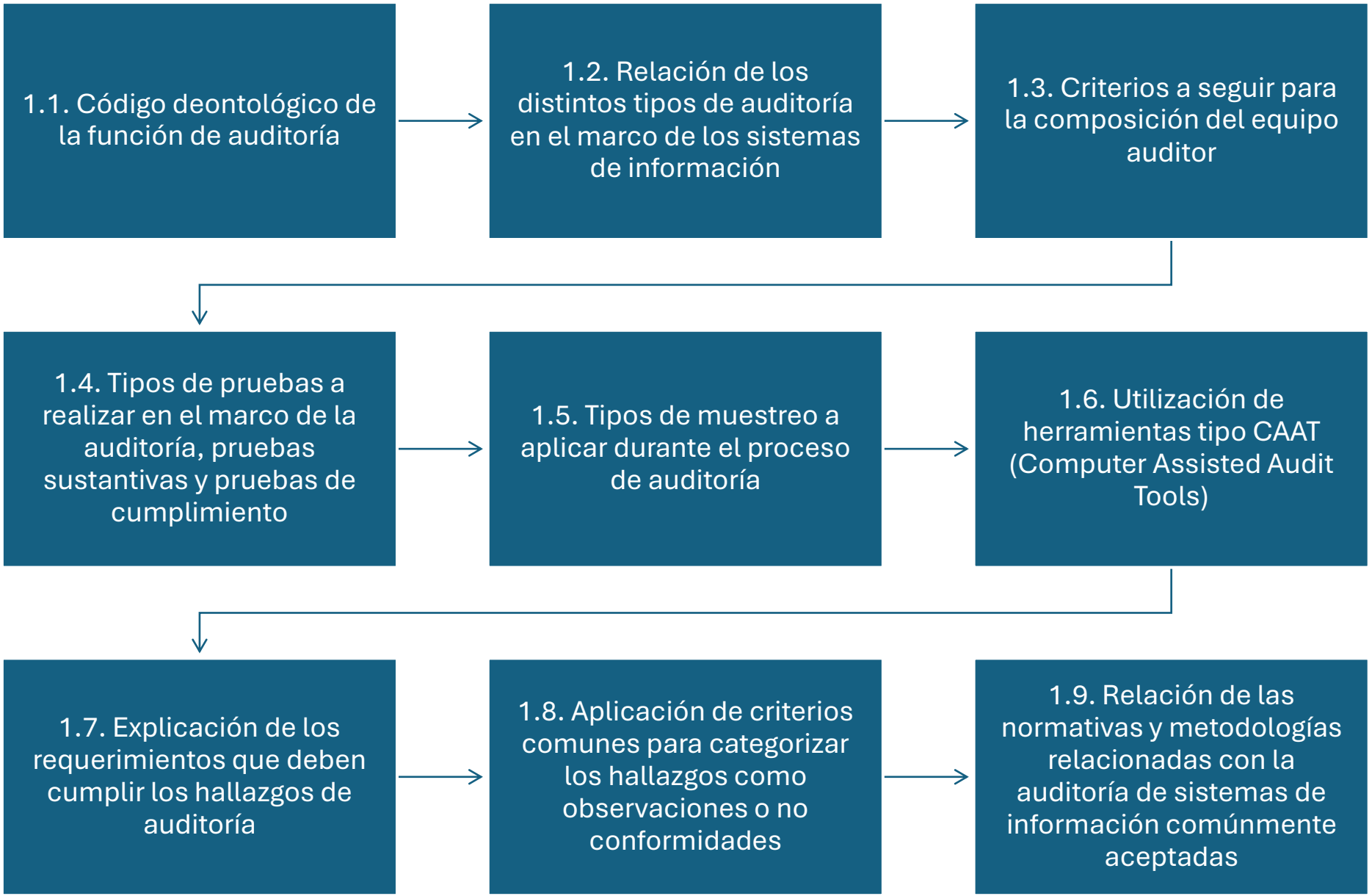
Criterios generales comúnmente aceptados sobre auditoría informática

Agrega una breve explicación del propósito de la presentación

Índice

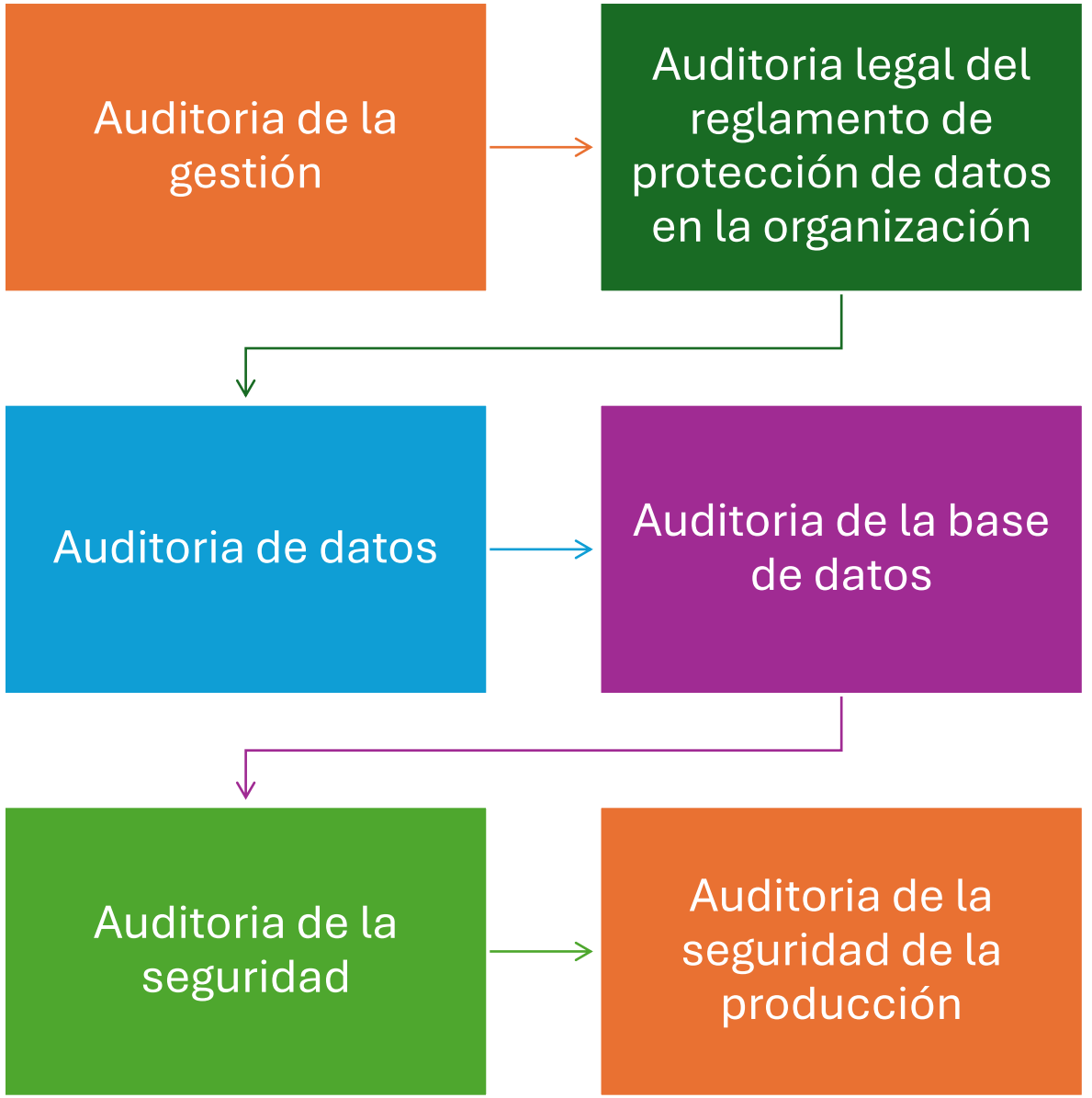

1.1. Código deontológico de la función de auditoría
1.2. Relación de los distintos tipos de auditoría en el marco de los sistemas de información
1.3. Criterios a seguir para la composición del equipo auditor
1.4. Tipos de pruebas a realizar en el marco de la auditoría, pruebas sustantivas y pruebas de cumplimiento
1.5. Tipos de muestreo a aplicar durante el proceso de auditoría
1.6. Utilización de herramientas tipo CAAT (Computer Assisted Audit Tools)
1.7. Explicación de los requerimientos que deben cumplir los hallazgos de auditoría
1.8. Aplicación de criterios comunes para categorizar los hallazgos como observaciones o no conformidades
1.9. Relación de las normativas y metodologías relacionadas con la auditoría de sistemas de información comúnmente aceptadas

1.1. Código deontológico de la función de auditoría

- **Auditoría**
- La **auditoría** es el proceso de revisión y verificación independiente de información, procesos o sistemas de una organización para comprobar su **veracidad, cumplimiento y eficiencia**.
-

- 📌 **Código deontológico de la auditoría**
- Es el conjunto de **principios éticos** que guían la labor del auditor, garantizando confianza y profesionalidad.
- **Principios básicos:**
- **Integridad** → actuar con honestidad.
- **Objetividad** → emitir juicios sin influencias externas.
- **Confidencialidad** → proteger la información obtenida.
- **Competencia profesional** → trabajar con conocimiento y diligencia.
- **Independencia** → evitar conflictos de interés.
- **Responsabilidad** → cumplir leyes y normas, generando confianza pública.

1.2. Relación de los distintos tipos de auditoría en el marco de los sistemas de información



1.2. Relación de los distintos tipos de auditoría en el marco de los sistemas de información

- Auditora web
- Auditoria a la red inalámbrica
- Auditoria al código fuente
- Auditoría a dispositivos móviles
- Auditoría a infraestructuras críticas
- Auditoría a la respuesta de incidentes

1.3. Criterios a seguir para la composición del equipo auditor

- Requisitos:
  - Conocimientos técnicos
  - Experiencia en auditorías
  - Certificaciones relevantes
  - Habilidades de comunicación
  - Conocimiento normativo y legal
  - Capacidad de trabajo en equipo
  - Independencia y objetividad
  - Flexibilidad y adaptabilidad
  - Documentación y gestión

Certificaciones

Certificaciones para auditores informáticos

CISA (Certified Information Systems Auditor) – ISACA

La más reconocida en auditoría informática.

Avala conocimientos en auditoría, control y seguridad de sistemas de información.

CISM (Certified Information Security Manager) – ISACA

Más orientada a la gestión de la seguridad.

Complementa a CISA si el auditor también ocupa roles de gestión.

ISO/IEC 27001 Lead Auditor

Certificación específica para auditar sistemas de gestión de seguridad de la información (SGSI) bajo la norma ISO 27001.

Muy demandada en empresas que aplican compliance y ciberseguridad.

CIA (Certified Internal Auditor) – IIA

Enfocada en la auditoría interna en general.

Útil cuando el auditor trabaja en un departamento de auditoría integral que incluye sistemas.

CEH (Certified Ethical Hacker) – EC-Council

Aunque no es de auditoría como tal, da prestigio porque certifica habilidades en hacking ético y pruebas de seguridad, muy usadas en auditorías técnicas.

CompTIA Security+ y CompTIA CySA+

De nivel intermedio.

Valoran conocimientos en seguridad informática, análisis de riesgos y respuesta a incidentes.

Componentes de un equipo auditor

- Director de la auditoría de sistemas de información
  - Gerente de la auditoria de sistemas de información
    - Auditores senior
    - Auditores de sistemas de información
    - Analista de datos o analista de ciberseguridad

Tipos de pruebas

- Sustantivas
  - Autenticación y autorización
  - Pruebas de registros y de eventos
  - Pruebas de vulnerabilidades
  - Pruebas de registros y eventos
  - Pruebas de vulnerabilidades
    - Evaluación del host
    - Evaluaciones de redes
    - Evaluaciones de aplicaciones
    - Evaluaciones de las bases de datos
  - Pruebas de penetración
  - Pruebas de continuidad y protección de datos

Tipos de pruebas

- Pruebas de cumplimiento
  - Lotes de pruebas
    - Carga de datos
    - Procesamiento de lotes
    - Monitorización y control
    - Rendimiento y eficiencia
    - Integridad de los datos
  - Simulación paralela
    - Pruebas integradas
    - Pruebas transaccionales
    - Comparación de programas
    - Cumplimiento normativo

Tipos de muestreo

- **Representatividad**
- Obtener conclusiones válidas de un conjunto grande a partir de una muestra pequeña.
- **Eficiencia**
- Reducir tiempo y costes en la auditoría, evitando revisar el 100% de la información.
- **Detección de errores o fraudes**
- Identificar irregularidades, riesgos o incumplimientos en los sistemas, procesos o datos.
- **Confianza en los resultados**
- Proporcionar un nivel razonable de seguridad de que la información auditada es **fiable**.
- **Soporte para la toma de decisiones**
- Ayudar al auditor a **emitir conclusiones y recomendaciones** con base en evidencia suficiente.

Tipos mas comunes de muestreo

- De registros
- De campos
- De transacciones
- De eventos o registros de auditoría
- De excepciones
- De acceso
- De penetración
- De flujo de trabajo

Utilización de herramientas tipo CAAT

- Son **herramientas asistidas por ordenador** que ayudan a los auditores a **analizar grandes volúmenes de datos**, comprobar integridad, detectar anomalías y automatizar pruebas.
-
- 🔹 **Ejemplos de herramientas CAAT**
- **ACL Analytics (Audit Command Language)**
  - Muy usada en auditoría financiera e informática.
  - Permite extraer, filtrar y analizar grandes bases de datos.
- **IDEA (Interactive Data Extraction and Analysis)**
  - Similar a ACL, especializada en análisis de datos y fraude.
- **Excel con macros / Power BI**
  - Útiles para auditorías pequeñas o análisis de información tabular.
- **SQL Queries**
  - Consultas SQL para revisar integridad de bases de datos.
- **Herramientas de auditoría de sistemas**
  - Ejemplo: Nmap, Wireshark, Splunk, que ayudan en auditoría informática de seguridad y redes.
- **Scripts propios en Python o R**
  - Para análisis de logs, correlación de eventos o detección de patrones anómalos.

Requerimientos de los hallazgos de auditoria

- Relevante
- Valida y confiable
- Independiente y fiable
- Clara y precisa
- Suficientemente detallada
- Clasificada
- Recomendaciones
- Temporalización
- Seguimiento
- Aprobación

Criterios

- Criterios comunes
  - Normas y regulaciones legales
  - Estándares internacionales
  - Políticas y procedimientos internos
  - Mejores practicas de la industria
  - Criterios específicos de proyectos
  - Acuerdos de nivel de servicio
  - Requisitos de seguridad
  - Practicas de gestión de proyectos y de datos
  - Resiliencia del sistema

Criterios

- Observación
- No conformidad
  - Clasificación
  - Gravedad
  - No cumple los criterios específicos de la auditoría
  - Evidencia
  - Estar documentadas
  - seguimiento

Reglamento	Referencia	Ámbito	Nota clave
GDPR – Reglamento General de Protección de Datos	**(UE) 2016/679**	Protección de datos personales	Aplicación directa en toda la UE.
DORA – Resiliencia Operativa Digital	**(UE) 2022/2554**	Resiliencia y gestión de riesgos TIC en sector financiero	Exige pruebas, gestión de terceros y reporting de incidentes.
Data Governance Act	**(UE) 2022/868**	Compartición y reutilización de datos	Fomenta intermediarios y altruismo de datos.
Data Act	**(UE) 2023/2854**	Acceso/uso de datos (IoT, contratos)	Reglas para datos generados por dispositivos.
eIDAS (y actualización eIDAS 2)	**(UE) 910/2014** (mod. 2024)	Identidad y servicios de confianza	Marcos de firma electrónica y cartera europea de identidad.
Cyber Resilience Act (CRA)	**(UE) 2024/…**	Ciberseguridad de productos con software/hardware	Requisitos de seguridad y ciclo de vida.
AI Act	**(UE) 2024/…**	Regulación de sistemas de IA por niveles de riesgo	Obligaciones de gestión de riesgos y transparencia.

Relación de las normativas y metodologías: a nivel europeo

Estándares a nivel internacional

Estándar / Marco	Referencia	Foco	Uso típico
ISO/IEC 27001	27001:2022/2024	SGSI	Certificación de seguridad de la información.
ISO/IEC 27002	27002:2022	Controles de seguridad	Catálogo de controles y buenas prácticas.
ISO/IEC 27005	27005:2024	Gestión de riesgos	Metodología de riesgos alineada a 27001.
ISO/IEC 27701	27701:2019	Privacidad (PIMS)	Extensión de 27001 para GDPR/privacidad.
ISO/IEC 27017 / 27018	27017/27018	Seguridad y PII en nube	Controles específicos para cloud.
ISO 22301	22301:2019	Continuidad de negocio	BIA, planes y pruebas de continuidad.
ISO/IEC 20000-1	20000-1:2018	Gestión de servicios TI	Integración con seguridad/operaciones.
ISO 31000	31000:2018	Gestión de riesgos	Marco general, multi-dominio.
NIST CSF	Versión 2.0	Marco de ciberseguridad	Identificar–Proteger–Detectar–Responder–Recuperar.
NIST SP 800-53	Rev. 5	Controles de seguridad	Sistemas federales/altamente regulados.
NIST SP 800-171	Rev. 3	CUI / proveedores	Requisitos para contratistas.
COBIT	2019/2023	Gobierno y gestión TI	Alineación con negocio/controles.
PCI DSS	v4.0	Seguridad en pagos	Comercios y proveedores de servicios.
OWASP ASVS / SAMM / Top 10	—	Seguridad de aplicaciones	Requisitos y madurez de desarrollo seguro.
ITIL	v4	Gestión de servicios	Operación y mejora continua.

España: leyes y reales decretos (regulación)

Norma	Referencia	Ámbito	Relación con la UE
LOPDGDD	Ley Orgánica 3/2018	Protección de datos	Desarrollo nacional de **GDPR**.
ENS – Esquema Nacional de Seguridad	**RD 311/2022**	Seguridad en la Adm. Pública y su sector público	Alineado con ISO 27001 y **NIS**.
Seguridad de redes y sistemas (NIS)	**RD-ley 12/2018** y **RD 43/2021**	Operadores esenciales y servicios digitales	Transposición de **NIS (2016)**; pendiente adaptación **NIS2**.
Servicios electrónicos de confianza	**Ley 6/2020**	Firma, sello, sello de tiempo, etc.	Implementa **eIDAS** en España.
Esquema Nacional de Interoperabilidad (ENI)	**RD 4/2010** (y normas técnicas)	Interoperabilidad y gestión documental	Soporta e-administración.
Ley General de Telecomunicaciones	**Ley 11/2022**	Redes/servicios de comunicaciones	Transpone varios marcos UE de telecom.
Procedimiento y régimen jurídico sector público	**Leyes 39/2015 y 40/2015**	Administración electrónica y seguridad	Exigen cumplimiento ENS/ENI.
Código Penal (delitos informáticos)	Arts. 197, 248, 264, etc.	Acceso ilícito, daños, fraudes	Armonización con directivas UE.

Estándares a nivel español

Estándar / Guía	Referencia	Foco	Nota
UNE-EN ISO/IEC 27001	Edición española de ISO 27001	SGSI	Publicada por **AENOR** (adopción nacional).
UNE-EN ISO/IEC 27002, 27005, 22301, 20000-1, 31000	UNE-EN …	Controles, riesgos, continuidad, servicios	Equivalentes nacionales de ISO.
ENS – Guías y Perfiles	**CCN-STIC serie 800**	Implementación del ENS	Controles, cumplimiento y auditoría ENS.
CCN-STIC (general)	Series 400/600/800/…	Criptografía, hardening, respuesta incidentes	Referencia técnica del **CCN**.
MAGERIT v3	Metodología oficial	Análisis y gestión de riesgos	Usada en AA.PP.; herramienta **PILAR**.
Esquema Nacional de Interoperabilidad – NTI	Diversas NTI	Metadatos, documentos, firma, políticas	Complemento del ENI/ENS.

Herramientas osint

- **¿Qué es OSINT?**
- **OSINT** significa recopilar información de fuentes **públicas y accesibles** (redes sociales, buscadores, registros públicos, webs, foros, DNS, etc.).
- Se utiliza en **ciberseguridad, auditoría, investigación y forense digital**.

Fuentes osint

- **Ejemplos de fuentes OSINT**
- **Motores de búsqueda** → Google, DuckDuckGo, Bing.
- **Metadatos de documentos** → información oculta en PDFs, imágenes, etc.
- **Registros de dominios** → WHOIS, DNS.
- **Redes sociales** → LinkedIn, Twitter/X, Facebook.
- **Dark web** (cuando se requiere en investigaciones).

Herramientas en Kali linux

- **theHarvester**
  - Busca **correos, dominios y hosts** relacionados con una empresa.
- theHarvester -d ejemplo.com -b google
- **Maltego CE**
  - Herramienta gráfica que genera **mapas de relaciones** entre personas, correos, dominios, redes sociales.
- **Metagoofil**
  - Extrae **metadatos** de documentos públicos de un dominio.
- metagoofil -d ejemplo.com -t pdf,doc,xls -l 50 -n 20 -o /tmp/resultados
- **Recon-ng**
  - Framework OSINT en consola para automatizar recolección de datos.
- **DNSenum**
  - Permite descubrir subdominios y servidores DNS.
- dnsenum ejemplo.com